

ISO/IEC 27001:2022

BGYS Uygulama Rehberi

14 yapı taşıyla bilgi güvenliği yönetim sistemini anlamak, kurmak ve işletmek

ISO 27001 BGYS ile muhatap olan herkes için renkli, şemalı pratik başvuru kılavuzu

Ekim 2026

İçindekiler ve okuma rehberi

Bu belge, bir bilgi güvenliği yönetim sistemini oluşturan 14 yapı taşını sade bir dille anlatır.

ISO/IEC 27001:2022 şartlarını yönetim sisteminin **14 yapı taşı** etrafında topladık. Her bölüm aynı düzeni izler: önce **özü**, ardından bir **şema**, sonra **pratikte nasıl yapılır** ve **hangi kanıtların tutulacağı**. Standart maddelerinin numaraları, bir denetçiyle konuşurken ya da standart metnini açarken size yol göstermesi için başlıkların altında yer alır.

1	**Kuruluşun bağlamı** Kapsam, ilgili taraflar, çevre analizi	4.1 – 4.4	**5**
2	**Liderlik ve taahhüt** Üst yönetimin sahiplenmesi	5.1, 9.3	**6**
3	**Bilgi güvenliği hedefleri** Ölçülebilir, iş hedefleriyle uyumlu sonuçlar	6.2	**6**
4	**Bilgi güvenliği politikası** Yönün ve taahhüdün yazılı hali	5.2, A.5.1	**7**
5	**Roller, sorumluluklar, yetkinlik** Kim neyden sorumlu, kim yetkin?	5.3, 7.1, 7.2	**8**
6	**Risk yönetimi** Belirle, analiz et, değerlendir, ele al	6.1, 8.2, 8.3	**9**
7	**İzleme ve ölçme** KPI, KRI, KCI ile performans, risk, uyum	9.1	**10**
8	**Dokümantasyon** Zorunlu belgeler ve kayıtlar	7.5	**12**
9	**İletişim** Ne, kime, ne zaman, nasıl	7.4	**13**
10	**Farkındalık** İnsanı en güçlü kontrol yapmak	7.3, A.6.3	**13**
11	**Tedarikçi ilişkileri** Zincirdeki güvenliği yönetmek	A.5.19 – A.5.23	**14**
12	**İç denetim** Sistemin kendi kendine sınavı	9.2	**15**
13	**Olay yönetimi** Tespit, müdahale, ders çıkarma	A.5.24 – A.5.28	**16**
14	**Sürekli iyileştirme** Uygunsuzluk, düzeltici faaliyet, gözden geçirme	10.1, 10.2, 9.3	**17**

Ek bölümler: Yönetim sistemlerinin entegrasyonu · 2022 sürümü: Ek A kontrolleri · 12 aylık yol haritası ve hazırlık listesi · Rol bazlı hızlı rehber ve sözlük

Nasıl okumalı?
Üst yönetim için 1, 2, 3, 6, 7 ve 14. bölümler yeterli bir ilk bakıştır. **BG yöneticisi ve proje ekibi** için tamamı. **Süreç sahipleri ve BT** için 5, 6, 8, 11 ve 13. bölümler. **Tüm çalışanlar** için 4, 10 ve 13. bölümlerin ilk sayfaları.

Renk kodu
Her yapı taşının kendi rengi vardır ve şemalarda, tablolarda ve başlıklarda aynı renkle tekrar eder; bir konuyu sayfayı çevirdiğinizde bile renginden tanıyabilirsiniz.

Neden bir yönetim sistemi?

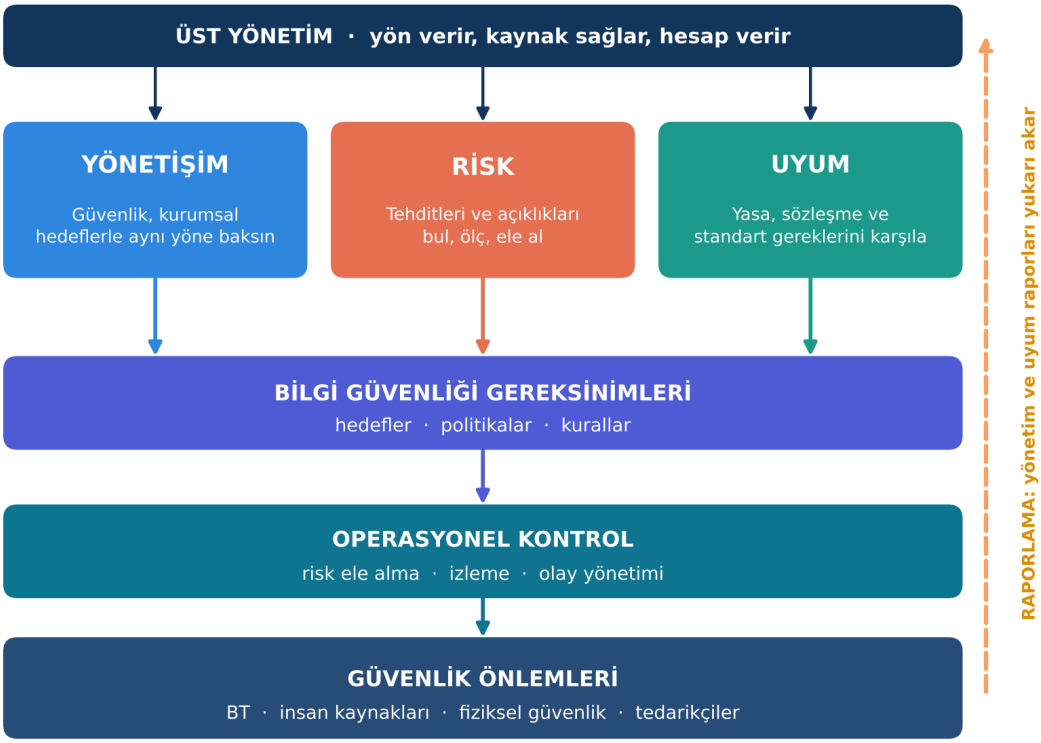
Bilgi güvenliği tek seferlik bir proje değil, sürekli işleyen bir yönetim disiplinidir.

Bilgi güvenliği çoğu kurumda hâlâ “BT'nin işi” olarak görülür. Oysa korunması gereken şey yalnızca sunucular değil; **kurumun bilgisi, itibarı, sözleşmeleri ve sürekliliğidir**. ISO/IEC 27001:2022, bunu rastlantıya bırakmadan, tekrarlanabilir ve kanıtlanabilir biçimde yönetmenin uluslararası şartlarını tanımlar. Bu şartlar bütününe **Bilgi Güvenliği Yönetim Sistemi (BGYS)** denir.

Gizlilik	Bütünlük	Erişilebilirlik
Bilgiye yalnızca yetkili kişiler ulaşır.	Bilgi doğru, eksiksiz ve izinsiz değiştirilmemiştir.	Bilgi, gerektiğinde ve gereken kişiye ulaşılabilir.

Sistem bu üç hedefi üç bakış açısıyla birlikte yönetir:

- **Yönetişim:** güvenlik hedefleri, kurumsal hedeflerden türer; üst yönetim yön verir ve hesap sorar.
- **Risk:** kurumun maruz kaldığı tehditler, açıklıklar ve olası etkiler belirlenir, değerlendirilir ve ele alınır.
- **Uyum:** yasa, düzenleme, sözleşme ve standart gereksinimleri tanımlanır ve karşılandığı gösterilir.



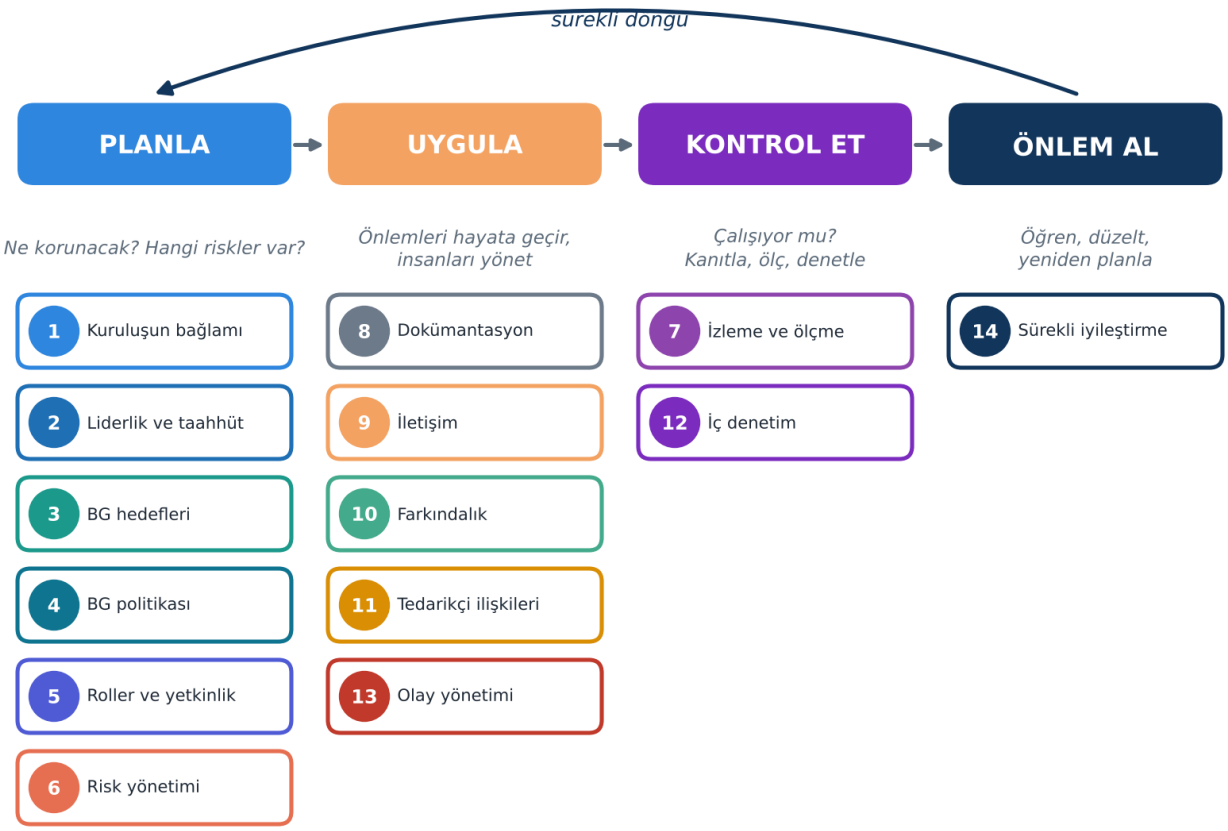
Şekil 1 · Bilgi güvenliği yönetim sisteminin üç bakışı ve kurum yönetimiyle ilişkisi

Önlemler iki sınavdan geçer
Bir güvenlik önlemi hem **etkili** olmalı (hedeflenen korumayı gerçekten sağlamalı) hem de **ekonomik** olmalıdır (maliyeti, korunan değerle orantılı). Standardın risk temelli yaklaşımı tam olarak bu dengeyi kurmak içindir.

14 yapı taşı haritası

Yönetim sisteminin parçalarını Planla – Uygula – Kontrol Et – Önlem Al döngüsünde görün.

BGYS tek bir belge ya da araç değildir; birbirini besleyen parçalardan oluşur. Aşağıdaki harita, parçaların döngüde nerede durduğunu gösterir. Planlama aşaması neyi, neden ve nasıl koruyacağınızı belirler; uygulama aşaması bunu hayata geçirir; kontrol aşaması işe yarayıp yaramadığını kanıtlar; önlem alma aşaması öğrenileni sisteme geri taşır.



Şekil 2 · Yapı taşlarının PDCA döngüsündeki yeri (numaralar bu belgedeki bölüm numaralarıdır)

Döngünün çıktıları:

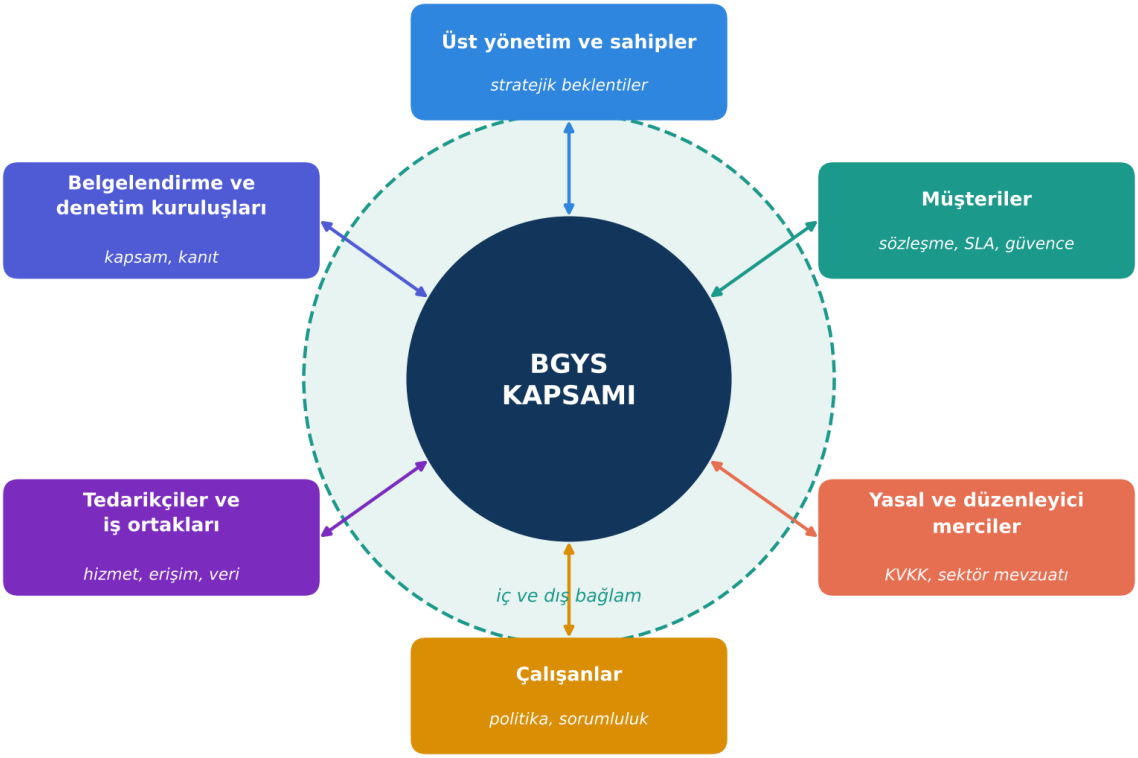
- **Planla** aşaması; kapsamı, ilgili tarafları, politikayı, hedefleri, rolleri ve risk yaklaşımını ortaya koyar.
- **Uygula** aşaması; riskleri ele alan kontrolleri işletir, insanları bilinçlendirir, tedarikçileri yönetir, olaylara hazır olur.
- **Kontrol et** aşaması; göstergelerle izler, iç denetimle sınar, sonucu üst yönetimin gözden geçirmesine taşır.
- **Önlem al** aşaması; uygunsuzlukların kök nedenini çözer ve sistemi olgunlaştırır.

İpucu: sırayla değil, birlikte düşünün
Yapı taşları sıralı bir kontrol listesi değildir. Örneğin risk değerlendirmesi, hedefleri ve politikayı da değiştirebilir; bir iç denetim bulgusu, farkındalık programının içeriğini etkileyebilir. İyi bir BGYS'de bu geri besleme doğaldır.

1 Kuruluşun bağlamı

Madde 4.1 – 4.4 · Kapsam, ilgili taraflar, çevre analizi

BGYS, kurumun boşlukta değil belirli bir ortamda çalıştığını kabul ederek başlar. İlk iş; hangi iç ve dış etkenlerin bilgi güvenliğini etkilediğini, kimlerin kurumdan ne beklediğini (**ilgili taraflar**) ve sistemin nereye kadar uzandığını (**kapsam**) yazıya dökmektir. Kapsam belirsiz kalırsa risk analizi, kaynak planı ve belgelendirme denetimi aynı anda sorunlu hale gelir.



Şekil 3 · BGYS kapsamı ve etkileşimde olduğu ilgili taraflar

Pratikte nasıl yapılır?

- İç ve dış bağlamı sade bir tabloyla çıkarın: strateji, teknoloji, mevzuat, rekabet, tedarik zinciri.
- İlgili tarafları ve beklentilerini listeleyin: müşteri sözleşmeleri, KVKK, sektör düzenlemeleri, çalışan beklentileri.
- Kapsamı süreç, lokasyon, varlık ve arayüzlerle tanımlayın; **dışarıda bıraktıklarınızı gerekçesiyle** yazın.
- Dış hizmet sağlayıcılarla arayüzü netleştirin: kim neyi yönetiyor, kim sorumlu?
- İklim değişikliği gibi ilgili dış konuların bağlamda değerlendirilip değerlendirilmediğine bakın (2024 değişikliği).

Kanıt ve kayıtlar

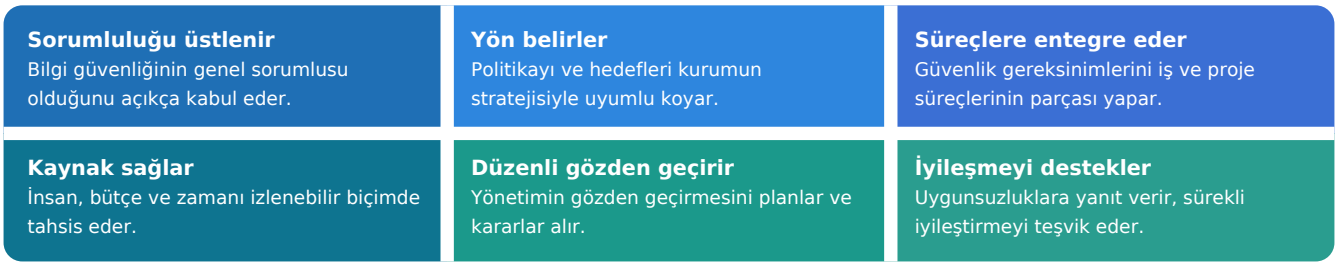
- **BGYS kapsam beyanı** (4.3, zorunlu)
- İlgili taraflar ve gereksinimleri listesi (4.2)
- Uygulanabilirlik Bildirgesi, SoA (6.1.3)
- Yasal, düzenleyici ve sözleşmesel gereksinim envanteri
- Bağlam analizi ve düzenli gözden geçirme notları

Sertifika tek başına yetmez
Bir tedarikçinin ISO 27001 sertifikası olması, sizin ihtiyaç duyduğunuz sürecin kapsamda olduğu anlamına gelmez. Müşteri olarak sertifikanın yanında **kapsam beyanını** da isteyin; kendi kapsamınızı da bu gözle yazın.

2 Liderlik ve taahhüt

Madde 5.1, 9.3 · Yönetimin sahiplenmesi

BGYS yukarıdan aşağıya kurulur. Üst yönetim bilgi güvenliğinin sahibi olduğunu göstermedikçe politika kâğıtta kalır. Standart yönetimden yalnızca onay değil, **örnek olmayı** ve somut kaynak ayırmayı bekler. Bu yaklaşım “tepeden gelen ton” olarak da bilinir: yönetim neye önem verirse kurum onu önemser.



Şekil 4 · Üst yönetimin altı temel görevi

Pratikte nasıl yapılır?

- BG yöneticisini (CISO / yönetim temsilcisi) yazılı atayın; yönetime doğrudan raporlama hattı kurun.
- Yılda en az bir kez, girdileri önceden hazırlanmış **yönetimin gözden geçirmesi** toplantısı yapın.
- Bütçe ve insan kaynağı kararlarını tutanağa geçirerek görünür kılın.
- Görünürlük sağlayın: açılış mesajı, eğitim videosu, olay sonrası değerlendirme.
- “Üst yönetim” tanımını kapsamla netleştirin (grup yönetimi mi, bölüm yönetimi mi?).

Kanıt ve kayıtlar

- **Yönetimin gözden geçirme tutanağı** (9.3, zorunlu)
- Karar ve eylem kayıtları, kaynak onayları
- Yönetime sunulan raporlar ve sunumlar
- Hedef ve risk durumuna ilişkin yönetim raporları

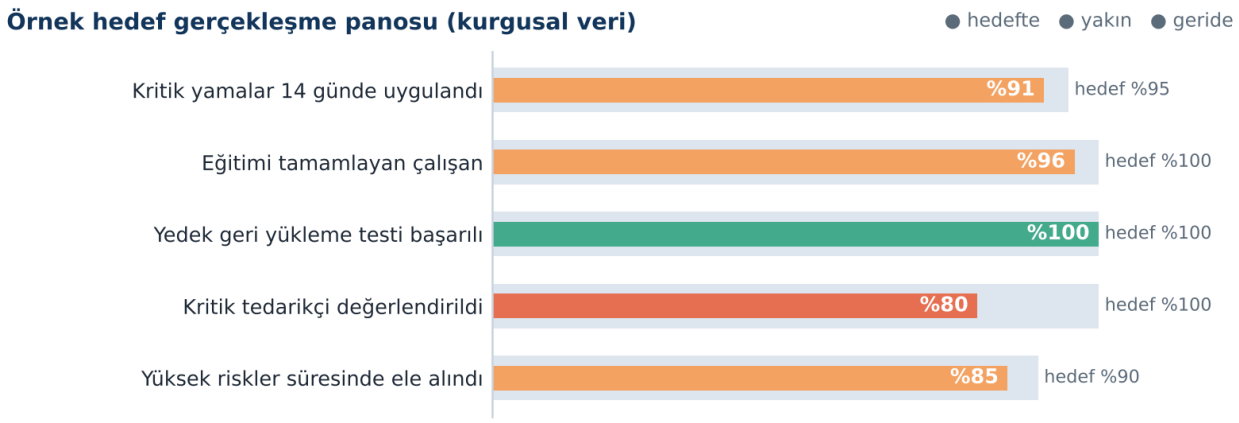
3 Bilgi güvenliği hedefleri

Madde 6.2 · Ölçülebilir, iş hedefleriyle uyumlu sonuçlar

Hedefler, politikadan türeyen ve kurumun iş hedefleriyle uyumlu somut sonuçlardır. “Güvenliği artırmak” bir hedef değildir; **“kritik yamaların %95'ini 14 gün içinde uygulamak”** bir hedeftir. Her hedef için ne yapılacağı, kimin sorumlu olduğu, hangi kaynakların gerektiği, ne zaman biteceği ve sonucun nasıl değerlendirileceği planlanmalıdır.

Harf	Ölçüt	Soru	Örnek
S	Özgül	Tam olarak neyi başarmak istiyoruz?	Uzaktan erişimde çok faktörlü kimlik doğrulama (MFA)
M	Ölçülebilir	Nasıl ölçeceğiz?	MFA kapsamındaki hesap oranı
A	Üzerinde uzlaşılmış	Sorumlu ve yönetim kabul etti mi?	BT müdürü sorumlu, yönetim onaylı
R	Gerçekçi	Kaynak ve süre yeterli mi?	Lisans ve ekip kapasitesi planlandı
T	Zaman sınırlı	Ne zamana kadar?	Haziran sonuna kadar %100

Tablo 1 · Hedefleri “SMART” ölçütleriyle sınayın



Şekil 5 · Hedeflerin gerçekleşme durumunun örnek bir görünümü

Pratikte nasıl yapılır?

- Az ama anlamlı hedefle başlayın (5–8 hedef); mükemmel liste yerine uygulanabilir liste hedefleyin.
- Hedefleri risk değerlendirmesinden, yasal gereksinimlerden ve iş hedeflerinden türetin.
- Her hedefe bir gösterge, bir sahip ve bir termin atayın; projelere bağlayın.
- Güvenlik gereksinimlerini ürün ve proje planlamasının en başına taşıyın.
- Hedefleri yılda en az bir kez ve büyük değişimlerde gözden geçirin.

Kanıt ve kayıtlar

- **Dokümante edilmiş hedefler** (6.2, zorunlu)
- Hedef eylem planı: ne, kim, kaynak, termin, değerlendirme
- Gerçekleşme raporları (bkz. bölüm 7)
- Yönetimin gözden geçirmesindeki hedef değerlendirmesi

4 Bilgi güvenliği politikası

Madde 5.2 · Ek A 5.1 · Yönün ve taahhüdün yazılı hali

Politika, üst yönetimin bilgi güvenliğine ilişkin yönünü ve taahhüdünü ifade eden **kısa** bir belgedir. Kurumun amacına uygun olmalı; hedefler koymak için bir çerçeve sunmalı; gereksinimleri karşılama ve sürekli iyileştirme taahhüdünü içermeli; yazılı olmalı, çalışanlara iletilmeli ve gerektiğinde ilgili taraflara verilebilmelidir.

Üstten alta: kısa, stratejik → ayrıntılı, operasyonel



Şekil 6 · Belge hiyerarşisi: yön, kural, yöntem, kanıt

Pratikte nasıl yapılır?	Kanıt ve kayıtlar
• Politikayı 1–2 sayfada tutun; ayrıntıyı konu bazlı politikalara (erişim, şifreleme, yedekleme…) bırakın. • Hazır şablonu olduğu gibi kullanmayın; kurumun dilini, hedeflerini ve kapsamını yansıtın. • Üst yönetim onaylasın; çalışanlara duyurulsun; gerektiğinde müşteri ve iş ortaklarına sunulabilsin. • Yılda bir ve önemli değişikliklerde gözden geçirin. • Sorumluluğu ayırın: politika yönetimin, ayrıntılı belgeler BG yöneticisi ve birimlerin.	• **Bilgi güvenliği politikası** (5.2, zorunlu) • Konu bazlı politikalar (Ek A 5.1) • Onay, yayım ve duyuru kayıtları • Çalışanların politikayı okuduğuna dair kayıtlar

Sık yapılan hata
Politikaya prosedür ayrıntısı doldurmak. Politika değiştikçe onay gerektirir; ayrıntı değiştikçe ise sık güncellenmelidir. İkisini ayrı belgelerde tutmak hem yönetimi hem denetimi kolaylaştırır.

5 Roller, sorumluluklar ve yetkinlik

Madde 5.3, 7.1, 7.2 · Kim neyden sorumlu, kim yetkin?

BGYS'nin işlemesi, kimin ne yaptığının net olmasına bağlıdır. En az bir **bilgi güvenliği yönetici** rolü (BG yöneticisi / CISO), ayrıca **risk sahibi** ve **varlık sahibi** rolleri tanımlanmalı; ilgili kişilerin **yetkin** olduğu kanıtlanabilmelidir. Sorumluluk ve yetki, çatışma yaratmayacak biçimde dağıtılmalıdır.

Faaliyet	Üst yön.	BG yön.	Risk sahibi	BT	İK	İç denetçi
Politikanın onayı	A	R	C	C	I	I
Risk değerlendirmesi	I	A	R	R	C	I
Risk kabulü (artık risk)	C	C	A / R	C	–	I
Erişim haklarının gözden geçirilmesi	–	C	A	R	C	I
Olay müdahalesi	I	A	C	R	C	I
İç denetim	I	C	C	C	C	A / R

Tablo 2 · Örnek RACI matrisi (R: yapar · A: hesap verir · C: danışılır · I: bilgilendirilir)

Çıkarılması gereken çatışma	Neden sorun?
BG yöneticisi ↔ BT müdürü	Güvenliği hem uygulayıp hem denetlemek, bağımsız görüşü zayıflatır.
Kişisel veri sorumlusu ↔ BT müdürü	Veri koruma ve operasyonel öncelikler çatışabilir (ör. log izleme).
İç denetçi ↔ sistem yöneticisi	Kişi kendi işini denetleyemez; görev ayrılığı gerekir.

Pratikte nasıl yapılır?	Kanıt ve kayıtlar
• BG yöneticisi rolünü görev tanımı, yetki ve yetkinlik gereksinimleriyle atayın. • Risk sahibini ve varlık sahibini **isimle** belirleyin; “BT” gibi birim adı yetmez. • Görev ayrılığını RACI ve yetki matrisleriyle belgeleyin. • Yetkinliği eğitim, sertifika, deneyim ve değerlendirmeyle kanıtlayın. • BG yöneticisinin iş hedefleri ile güvenlik risklerini “tercüme edebilen” biri olmasına özen gösterin.	• **Yetkinlik kanıtları** (7.2, zorunlu) • Görev tanımları ve atama yazıları • RACI / yetki matrisi • Eğitim ve sertifika kayıtları • Kaynak planı (7.1)

6 Risk yönetimi

Madde 6.1, 8.2, 8.3 · ISO 31000 ve ISO/IEC 27005 ile uyumlu

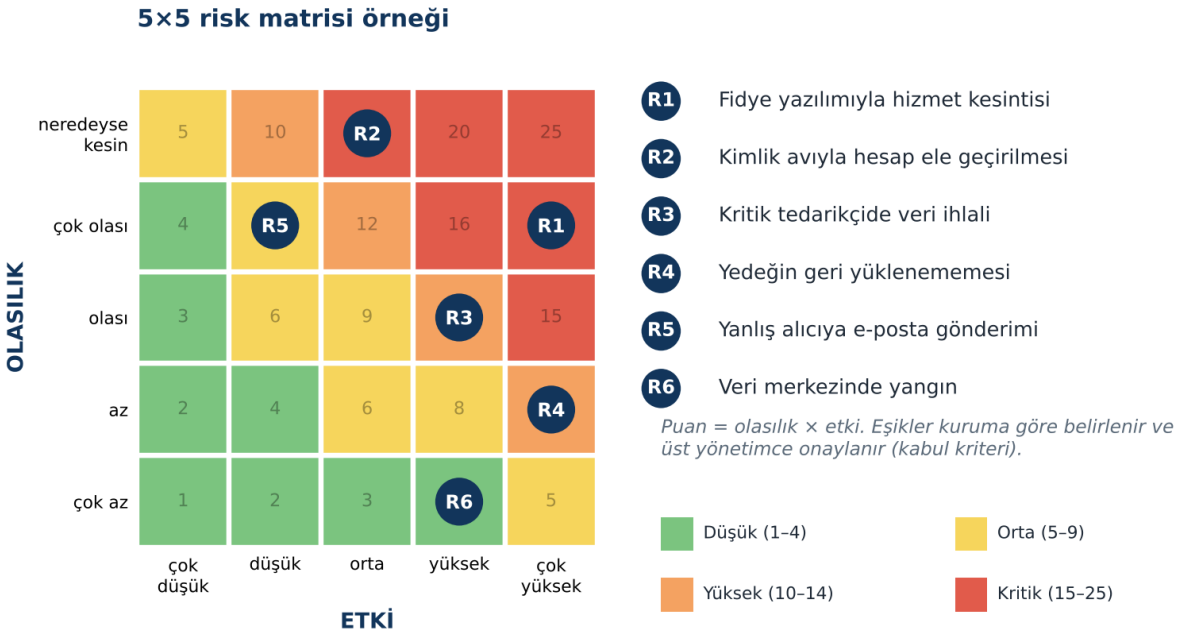
Risk yönetimi BGYS'nin kalbidir. Bir **bilgi güvenliği riski**, bir tehdidin bir açıklıktan yararlanarak gizlilik, bütünlük veya erişilebilirliği bozması ve iş süreçlerine zarar vermesi ihtimalidir. Amaç riski sıfırlamak değil, **kabul edilebilir seviyeye** indirmektir. Kabul edilebilirliğin ne olduğuna ise üst yönetim karar verir.



Şekil 7 · Risk yönetimi süreci

Önce hazırlık: yöntem ve kriterler

Risk bulmaya başlamadan **risk değerlendirme yöntemi**, **değerlendirme ölçütleri** ve **risk kabul kriteri** üst yönetimle birlikte belirlenmelidir. Başarı büyük ölçüde hazırlığa bağlıdır. Kabul kriterleri, hangi riskin kim tarafından kabul edilebileceğini de (örn. belirli seviyenin üstünü yalnızca yönetim kurulu kabul eder) tanımlar.



Şekil 8 · Risk matrisi örneği: olasılık × etki ile risk seviyeleri

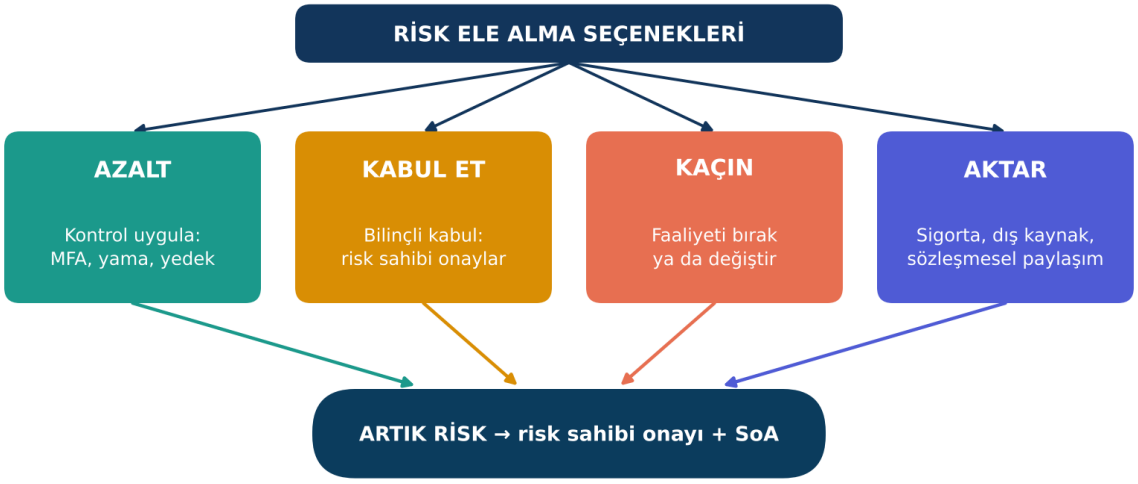
Risk nasıl bulunur?

- **Görüşme ve çalıştaylar:** iş birimi, BT, hukuk ve güvenlik aynı masada, farklı riskleri görür.
- **Senaryo ve "ya olursa" analizi:** kritik süreç için gerçekçi olay senaryoları kurun.
- **İş etki analizi (BIA):** hangi süreç ne kadar kesintiyi kaldırabilir?
- **Kontrol listeleri, Delphi, beyin fırtınası, STRIDE** gibi tehdit modelleme teknikleri.

- **Denetim bulguları, olaylar ve operasyonel gözlemler:** yaşayan riskin en güvenilir kaynağı.

Risk sahibi ve ele alma

Her riskin bir **risk sahibi** olmalıdır: etkisini iş olarak yaşayan, kaynağa karar verebilen yönetici. BT riski azaltmaya yardım eder, ancak riskin sahibi iş birimidir. Ele alma seçenekleri dört başlıkta toplanır; kalan **artık risk** sahibince onaylanır. Seçilen kontroller Ek A ile karşılaştırılarak hiçbir gerekli kontrolün atlanmadığı doğrulanır; sonuç **Uygulanabilirlik Bildirgesi'nde (SoA)** gerekçesiyle kayıt altına alınır.



Şekil 9 · Risk ele alma seçenekleri

Pratikte nasıl yapılır?

- Riskleri varlık yerine **iş süreci** diliyle yazın; risk sahibi anlar, etkiyi daha doğru ölçer.
- Risk analizini değişiklik yönetimine ve proje sürecine zorunlu adım olarak ekleyin.
- Küçük başlayın: basit bir modelle ilk riskleri toplayın, kriterleri sonuçlara bakarak olgunlaştırın.
- Eşiği aşan riskleri yazılı kabul veya plan olmadan açık bırakmayın.
- Risk kaydı gizli bilgi içerir: erişimi rol bazlı kısıtlayın.

Kanıt ve kayıtlar

- **Risk değerlendirme süreci** (6.1.2) ve **ele alma süreci** (6.1.3)
- Risk değerlendirme ve ele alma **sonuçları** (8.2, 8.3)
- Uygulanabilirlik Bildirgesi (SoA)
- Risk ele alma planı ve artık risk onayı
- Risk kaydı (zorunlu değil ama fiilen şart)

Risk matrisi ipucu
Çift sayılı bir matris (4×4) “ortada kalma” eğilimini ortadan kaldırır; tek sayılı (3×3, 5×5) matrislerde ise karar çoğunlukla ortadaki hücreye yığılır. Hangisini seçerseniz seçin, eşikleri önceden yazın ve tüm kuruma aynı şekilde uygulayın.

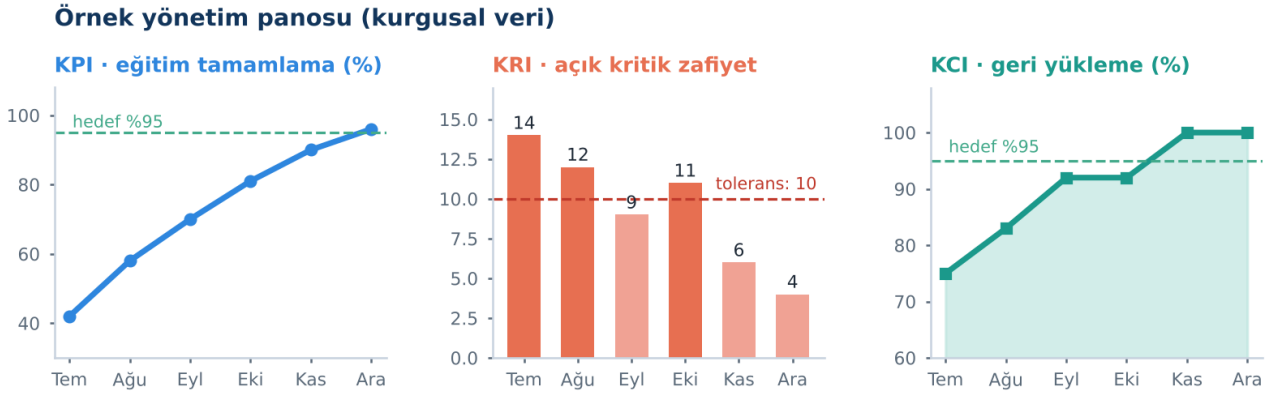
7 İzleme, ölçme ve değerlendirme

Madde 9.1 · Performans, risk ve uyum için gösterge yönetimi

Kurulu sistem kendi kendine çalışıyor sayılmaz; çalıştığı **ölçülerek** gösterilir. 9.1 maddesi neyin izleneceğini, hangi yöntemle, ne zaman, kim tarafından ölçüleceğini ve sonucun kim tarafından değerlendirileceğini belirlemenizi ister. Üç gösterge sınıfı bu işi kolaylaştırır: **KPI** (başarı), **KRI** (risk), **KCI** (kontrol etkinliği).



Şekil 10 · Üç gösterge sınıfı ve yönettikleri soru



Şekil 11 · Örnek yönetim panosu: hedefe yaklaşma, eşik aşımı, kontrol etkinliği

Pratikte nasıl yapılır?

- Az ama anlamlı gösterge seçin; her gösterge için formül, kaynak, sıklık ve sahip yazın.
- Her hedefin en az bir göstergesi, her kritik riskin bir erken uyarı göstergesi (KRI) olsun.
- Kontrollerin yalnızca “var” olduğunu değil, **çalıştığını** da ölçün (ör. yedeği gerçekten geri yükleyip denemek).
- Eşik aşımında kimin, ne zaman, ne yapacağını önceden tanımlayın.
- Sonuçları tek bir panoda toplayın ve yönetimin gözden geçirmesine taşıyın.

Kanıt ve kayıtlar

- **İzleme ve ölçüm sonuçları** (9.1, zorunlu)
- Gösterge tanımları (formül, sıklık, sahip)
- Pano ve periyodik raporlar
- Eşik aşımı için kayıtlı aksiyonlar

8 Dokümantasyon

Madde 7.5 · Zorunlu belgeler ve kayıtlar

BGYS'de belge, kendi başına amaç değildir; **kontrolün tutarlı çalıştığını** ve sonuçlarının izlenebilir olduğunu gösterir. Standart “belgelenmiş bilgi” der ve iki türü kapsar: yazılı kuralları (*belge*) ve yapılan işin kanıtını (*kayıt*). Ne kadar belge gerektiği kurumun büyüklüğüne, süreçlerin karmaşıklığına ve çalışanların yetkinliğine bağlıdır.

Madde	Zorunlu belgelenmiş bilgi	Tür
4.3	BGYS kapsamı	Belge
5.2	Bilgi güvenliği politikası	Belge
6.1.2	Risk değerlendirme süreci	Belge
6.1.3	Risk ele alma süreci ve Uygulanabilirlik Bildirgesi (SoA)	Belge
6.2	Bilgi güvenliği hedefleri	Belge
7.2	Yetkinliğin kanıtı	Kayıt
8.1	Süreçlerin planlandığı gibi yürütüldüğüne güven veren kayıtlar	Kayıt
8.2	Risk değerlendirme sonuçları	Kayıt
8.3	Risk ele alma sonuçları	Kayıt
9.1	İzleme ve ölçüm sonuçları	Kayıt
9.2	İç denetim programı ve denetim sonuçları	Kayıt
9.3	Yönetimin gözden geçirme sonuçları	Kayıt
10.2	Uygunsuzluklar ve düzeltici faaliyet sonuçları	Kayıt

Tablo 3 · ISO/IEC 27001:2022'nin açıkça zorunlu kıldığı belgelenmiş bilgiler (maddelere göre)

Pratikte nasıl yapılır?

- Her belgede sürüm, sahip, onay tarihi ve gözden geçirme sıklığı bulunsun.
- Belge kontrolü: oluşturma, onay, dağıtım, erişim, saklama ve imha kurallarını tanımlayın.
- Dış kaynaklı belgeleri (sözleşme, mevzuat, tedarikçi raporu) de kontrol altında tutun.
- “Gerektiği kadar yazın”: denetçi için değil, işi yapan kişi için yazın.
- Belge yapınızı; politika, konu bazlı politika, prosedür, kayıt basamaklarıyla kurgulayın.

Kanıt ve kayıtlar

- Belge ana listesi ve sürüm geçmişi
- Onay ve yayım kayıtları
- Erişim yetkileri ve saklama süreleri tablosu
- Belge gözden geçirme takvimi

9 İletişim

Madde 7.4 · Ne, kime, ne zaman, nasıl?

İyi çalışan bir BGYS, doğru bilginin doğru kişiye doğru zamanda ulaşmasına dayanır. Standart, iç ve dış iletişimde şu beş soruyu yanıtlamanızı ister: **neyi, ne zaman, kiminle, nasıl** ve **kim** iletecek? Bu planı yazmak, kriz anında kimin konuşacağı ve neyin paylaşılacağı konusundaki belirsizliği ortadan kaldırır.

Ne iletilir?	Kime?	Ne zaman?	Kim iletir?	Nasıl?
Politika ve hedefler	Tüm çalışanlar	İşe girişte, değişimde	BG yöneticisi	İntranet, eğitim
Performans ve risk raporu	Üst yönetim	Aylık / çeyreklik	BG yöneticisi	Pano, toplantı
Olay bilgisi	Etkilenenler, müşteri, düzenleyici	Olay anında ve yasal sürelerde	Olay ekibi + hukuk	Resmi yazı, e-posta
Güvenlik gereksinimleri	Tedarikçiler	Sözleşmede, yıllık	Satın alma	Sözleşme, portal
İç denetim sonuçları	Süreç sahipleri	Denetim sonrası	İç denetçi	Kapanış toplantısı

Tablo 4 · Örnek iletişim planı

Pratikte nasıl yapılır?

- İletişim planını hedef kitleye göre sadeleştirin: yöneticiye sonuç ve karar, çalışana yapılacak davranış.
- Tek yönlü yayın yetmez: bildirim hattı, soru-cevap ve geri bildirim kanalı açın.
- Dış iletişim yetkisini yazılı belirleyin; kriz anında “tek ses” ilkesi işlesin.
- Yasal bildirim sürelerini (örn. kişisel veri ihlalinde 72 saat) planın içine yazın.
- İletişimin işe yarayıp yaramadığını ölçün: okunma, anlama, geri bildirim.

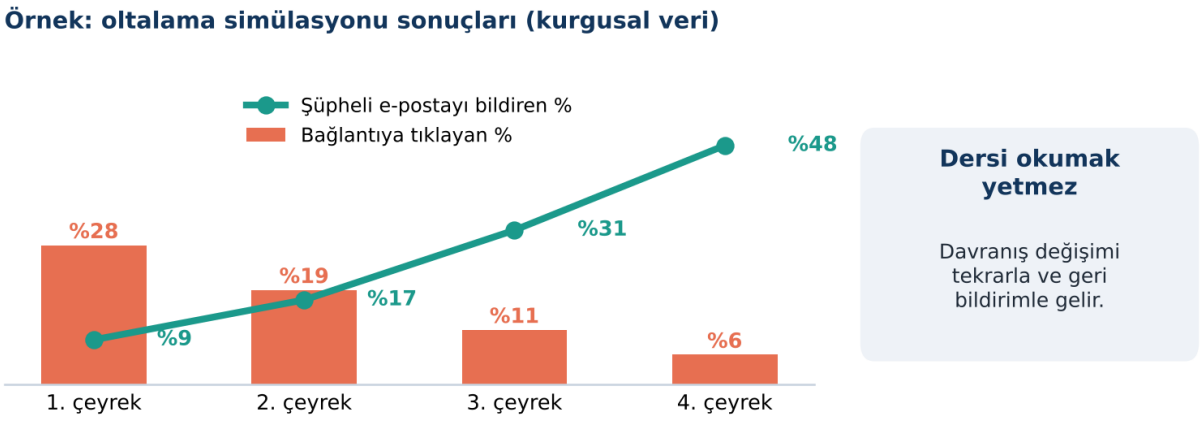
Kanıt ve kayıtlar

- İletişim planı ve sorumlular
- Duyuru, bülten ve toplantı kayıtları
- Bildirim ve yazışma arşivi
- Geri bildirim ve anket sonuçları

10 Farkındalık

Madde 7.3 · Ek A 6.3 · İnsanı en güçlü kontrol yapmak

Teknik önlemler ne kadar iyi olursa olsun, en sık kullanılan saldırı yolu hâlâ insandır. Standart, çalışanların politikayı bilmesini, BGYS'nin etkinliğine kendi katkılarını anlamasını ve gereklere uymamanın sonuçlarını bilmesini bekler. Farkındalık bu yüzden **yılda bir slayt gösterisi** değil, davranışı değiştiren sürekli bir programdır.



Şekil 12 · Davranış değişimi: tıklama oranı düşerken bildirim oranı yükselir (kurgusal)

Pratikte nasıl yapılır?	Kanıt ve kayıtlar
• İşe girişte, yılda bir ve rol bazlı (yönetici, yazılımcı, BT yöneticisi) eğitim verin. • Kısa, sık ve senaryo temelli öğrenin; gerçek olay örneklerini kullanın. • Oltalama simülasyonlarını **suçlamadan** yapın; şüpheyi bildirenleri ödüllendirin. • Yöneticiler örnek olsun: temiz masa, kilitli ekran, güçlü kimlik doğrulama. • Ölçün: katılım, test sonucu, tıklama ve bildirim oranları, olay trendi.	• Eğitim programı ve takvimi • Katılım listeleri ve test sonuçları (yetkinlik kanıtı) • Simülasyon raporları ve trendler • Duyuru, poster, bülten arşivi

11 Tedarikçi ilişkileri

Ek A 5.19 – 5.23 · Zincirdeki güvenliği yönetmek

Bilgi güvenliği kurumun duvarlarında bitmez; bulut sağlayıcılar, yazılım ve hizmet firmaları da verinizi işler. Tedarikçi güvenliği **sözleşme öncesinden başlayıp ilişki bitene kadar** yönetilen bir yaşam döngüsüdür. Bağımlılık ve risk arttıkça, isteyeceğiniz kontrol ve kanıt da artmalıdır.



Yaşam döngüsü boyunca ilke: bağımlılık arttıkça kontrol ve kanıt isteği de artar.

Şekil 13 · Tedarikçi yaşam döngüsü

Kritiklik	Tedarikçi örneği	Beklenen kontrol
Kritik	Bulut altyapı, yönetilen BT, veri işleyen yazılım	ISO 27001 sertifikası ve kapsam doğrulaması, denetim hakkı, olay bildirim süresi, yıllık gözden geçirme
Önemli	Sınırlı veriye erişen hizmet, danışman	Güvenlik anketi, gizlilik ve güvenlik maddeleri, yıllık kontrol
Standart	Veriye erişmeyen genel hizmet	Standart sözleşme ve gizlilik taahhüdü

Tablo 5 · Kritikliğe göre kademeli tedarikçi yönetimi

Pratikte nasıl yapılır?	Kanıt ve kayıtlar
• Tedarikçi envanteri oluşturun: ne sağlıyor, hangi veriye ve sisteme erişiyor? • Sözleşmeye güvenlik gereksinimi, alt yüklenici kuralı, olay bildirim süresi ve denetim hakkı ekleyin. • Bulut hizmetleri için giriş, kullanım ve **çıkış** stratejisini baştan düşünün (Ek A 5.23). • Sertifikanın kapsamının sizin hizmetinizi kapsadığını doğrulayın. • İlişki bitince erişimi kapatın, veriyi iade veya imha ettirin, kaydını tutun.	• Tedarikçi envanteri ve kritiklik sınıfı • Değerlendirme ve onay kayıtları • Sözleşmeler ve gizlilik taahhütleri • İzleme raporları, SLA ve olay kayıtları

12 İç denetim

Madde 9.2 · Sistemin kendi kendine sınavı

İç denetim, BGYS'nin hem kurumun kendi kurallarına hem de standarda **uygun** ve **etkin** biçimde işletildiğini planlı aralıklarla sınar. Bağımsız ve tarafsız yapılmalıdır; kapsamın tamamını bir denetim döngüsünde kapsayan bir program, denetim ölçütleri ve yetkin denetçilerle yürütülmelidir. Sonuçlar yönetime raporlanır.



Şekil 14 · İç denetim süreci

Bulgu sınıfı	Anlamı	Beklenen aksiyon
Majör uygunsuzluk	Bir gereksinim hiç veya sistematik olarak karşılanmıyor; sistemin amacını tehdit ediyor.	Kök neden analizi, düzeltici faaliyet, kısa termin, doğrulama
Minör uygunsuzluk	Gereksinim tekil veya sınırlı ölçüde karşılanmıyor.	Düzeltme ve düzeltici faaliyet planı
Gözlem	Henüz uygunsuzluk değil, ama risk oluşturabilir.	Sahibi değerlendirir, izler
İyileştirme fırsatı	Sistemi güçlendirecek öneri.	İsteğe bağlı, yönetimin gözden geçirmesine taşınır

Tablo 6 · Sık kullanılan bulgu sınıfları (sınıflandırma kuruma göre değişebilir)

Pratikte nasıl yapılır?

- Riske dayalı, tüm kapsamı bir döngüde (örn. yıllık) kapsayan bir denetim programı hazırlayın.
- Denetçi seçerken yetkinliği ve bağımsızlığı birlikte düşünün.
- Kanıta dayalı çalışın: kayıt, gözlem, görüşme; “bence” değil “şu kayıt gösteriyor”.
- Bulguları kök nedeniyle, sorumlu ve termin ile kapatın; kapanışta etkinliği doğrulayın.
- Denetim yöntemi için ISO 19011, BGYS'ye özel rehberlik için ISO/IEC 27007'den yararlanın.

Kanıt ve kayıtlar

- **İç denetim programı** ve denetim planları (9.2, zorunlu)
- **Denetim raporları ve bulgu kayıtları**
- Denetçi yetkinlik ve bağımsızlık kayıtları
- Düzeltici faaliyet ve kapanış kayıtları

13 Olay yönetimi

Ek A 5.24 – 5.28 · Tespit, müdahale, ders çıkarma

Önlemlere rağmen olaylar yaşanır; fark, hazırlıklı olup olmadığınızdır. Olay yönetimi, bir bilgi güvenliği olayının **tespit edilmesi, değerlendirilmesi, müdahale edilmesi ve sonrasında öğrenilmesi** için planlı bir süreçtir. Hızlı ve düzenli müdahale, hem zararı hem yasal ve itibar sonuçlarını azaltır.



Şekil 15 · Olay yönetimi yaşam döngüsü

Seviye	Tanım (örnek)	Örnek hedef müdahale
1 · Düşük	Tek kullanıcı, sınırlı etki, hizmet kesintisi yok	3 iş günü
2 · Orta	Bir birim veya hizmet kısmen etkileniyor	1 iş günü
3 · Yüksek	Kritik hizmette kesinti veya kişisel veri ihlali şüphesi	4 saat
4 · Kritik	Geniş çaplı kesinti, büyük veri sızıntısı, yasal bildirim	1 saat

Tablo 7 · Örnek olay sınıflandırması (süreleri kendi kurumunuza göre belirleyin)

Pratikte nasıl yapılır?

- Tek bir bildirim kanalı ve herkesin bildiği bir telefon/e-posta adresi belirleyin.
- Olay, zafiyet ve sorun kavramlarını ayırın; sınıflandırma kriterlerini yazın.
- Müdahale ekibini, rollerini ve karar yetkilerini önceden belirleyin; yılda en az bir tatbikat yapın.
- Delilleri koruyun (Ek A 5.28): kim, ne zaman, neyi topladı kayda geçsin.
- Kişisel veri ihlalinde yasal bildirim sürelerini (KVKK: öğrenildiğinden itibaren en geç 72 saat) önceden planlayın.
- Her önemli olaydan sonra ders çıkarın ve risk kaydını güncelleyin.

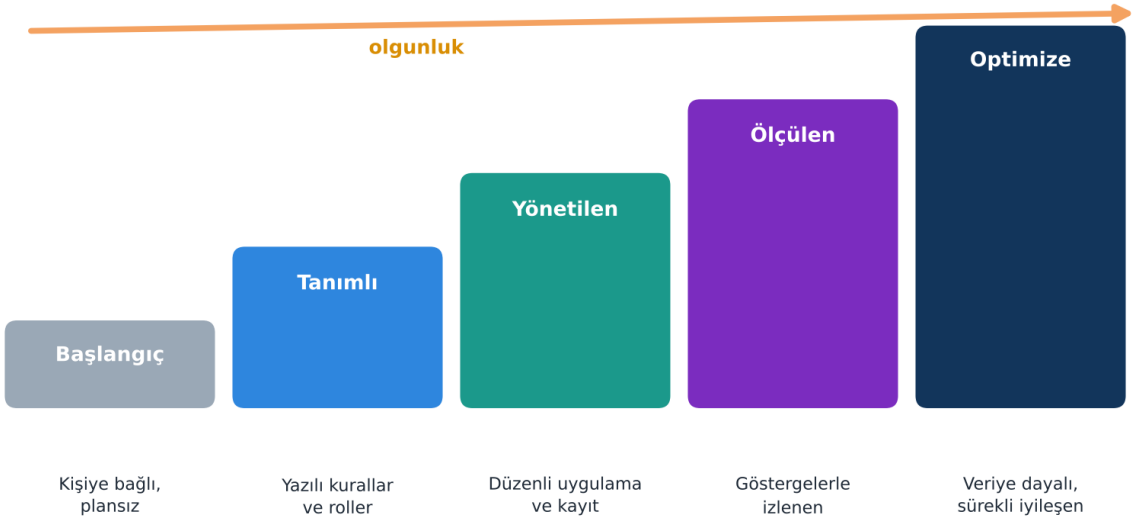
Kanıt ve kayıtlar

- Olay kayıt defteri ve sınıflandırma
- Müdahale ve kurtarma kayıtları
- Olay sonrası inceleme raporu
- Yasal ve müşteri bildirimlerinin kayıtları
- Tatbikat planı ve sonuçları

14 Sürekli iyileştirme

Madde 10.1, 10.2, 9.3 · Uygunsuzluk, düzeltici faaliyet, gözden geçirme

BGYS bir kez kurulup bırakılmaz. Hedef, sistemin **uygunluğunu, yeterliliğini ve etkinliğini** sürekli iyileştirmektir. İyileştirmenin üç beslenme kaynağı vardır: izleme sonuçları, iç denetim bulguları ve olaylar. Hepsi uygunsuzluk ve düzeltici faaliyet mekanizmasında, oradan da yönetimin gözden geçirmesinde buluşur.



Şekil 16 · Olgunluk merdiveni

Uygunsuzluk geldiğinde ne yapılır? (10.2)

1 · Tepki ver: kontrol altına al, düzelt, sonuçlarıyla ilgilen.

2 · Kök nedeni bul: neden oldu, başka yerde olabilir mi?

3 · Düzeltici faaliyet: gerekiyorsa uygula; sorumlu ve termin ata.

4 · Etkinliği gözden geçir: faaliyet işe yaradı mı?

5 · Sistemi güncelle: gerekiyorsa BGYS'de değişiklik yap; kaydet.

Yönetimin gözden geçirmesi · Girdiler (9.3.2)

- Önceki toplantı kararlarının durumu
- BGYS ile ilgili iç ve dış konulardaki değişiklikler
- İlgili tarafların ihtiyaç ve beklentilerindeki değişiklikler
- Performans geri bildirimi: uygunsuzluklar, izleme-ölçüm, iç denetim, hedeflere ulaşma
- İlgili taraf geri bildirimi
- Risk değerlendirme sonuçları ve ele alma planı durumu
- İyileştirme fırsatları

Yönetimin gözden geçirmesi · Çıktılar (9.3.3)

- Sürekli iyileştirme fırsatları
- BGYS'de değişiklik ihtiyaçları
- Kaynak kararları

Kararlar belgelenir ve eylem listesine dönüşür; bir sonraki toplantıda durumları ilk gündem maddesidir.

Pratikte nasıl yapılır?

- Her uygunsuzluğu bir fırsat olarak görün: önce kök neden, sonra çözüm.
- Düzeltici faaliyetleri tek bir izleme listesinde toplayın; vadesi geçenleri yönetime raporlayın.
- Yönetimin gözden geçirmesini yılda en az bir kez; olgunlaştıkça çeyreklik yapın.
- Olgunluğu hedefleyin: plansızdan tanımlıya, yönetilene, ölçülene, optimize edilene.
- İyileştirmeleri BGYS'ye geri yazın: politika, risk, hedef, eğitim.

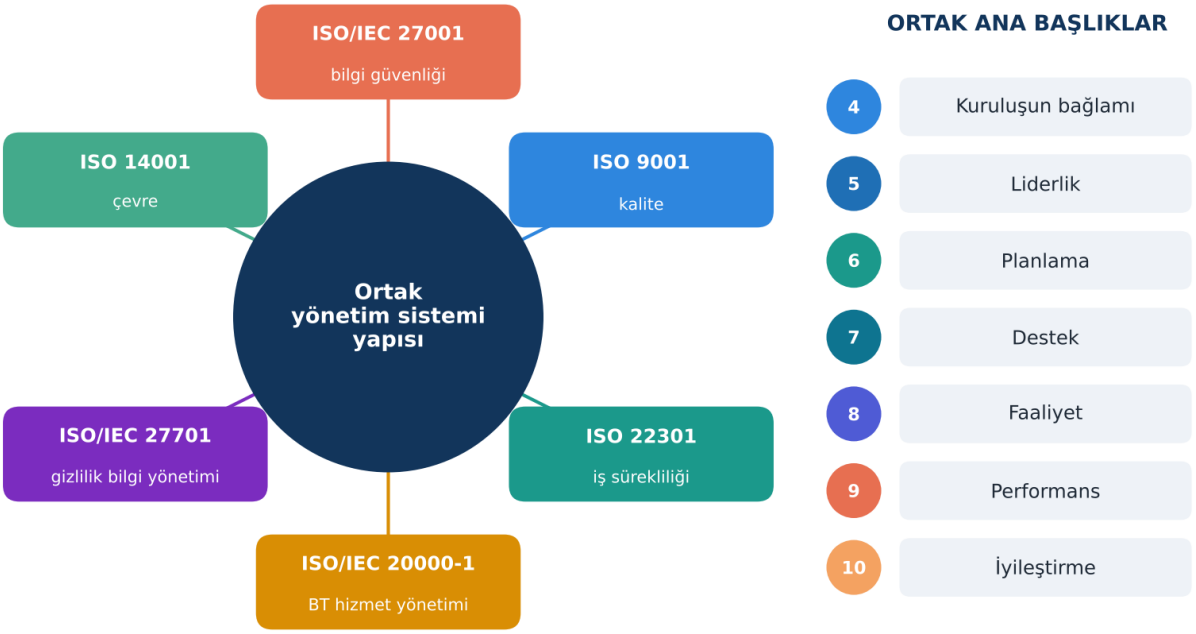
Kanıt ve kayıtlar

- **Uygunsuzluk ve düzeltici faaliyet kayıtları** (10.2, zorunlu)
- **Yönetimin gözden geçirme sonuçları** (9.3, zorunlu)
- İyileştirme planı ve takip listesi
- Yeniden değerlendirme ve etkinlik doğrulama kayıtları

Yönetim sistemlerinin entegrasyonu

ISO 27001 çoğu zaman tek başına değil, diğer standartlarla birlikte işletilir.

ISO/IEC 27001, ISO 9001, ISO 22301, ISO/IEC 20000-1, ISO/IEC 27701 ve ISO 14001 gibi güncel yönetim sistemi standartları aynı **ortak ana başlık yapısını** kullanır (bağlam, liderlik, planlama, destek, faaliyet, performans değerlendirme, iyileştirme). Bu yüzden aynı kurum, ortak bileşenleri tek kez kurup birden fazla standart için kullanabilir.



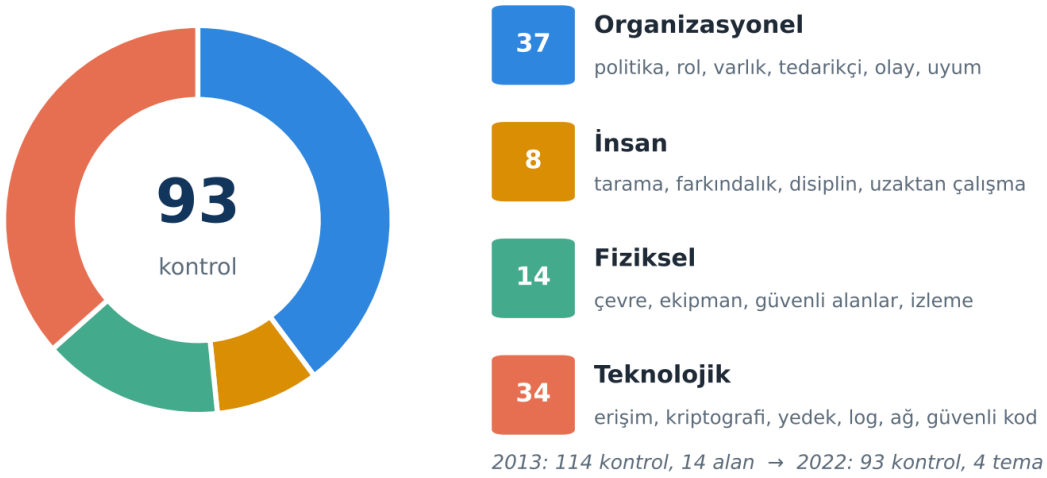
Şekil 17 · Ortak yapı üzerinde birden fazla yönetim sistemi standardı

Ortak kullanılabilen	Standarda özgü kalan
Bağlam analizi ve ilgili taraflar	Bilgi güvenliği risk değerlendirmesi ve Ek A kontrolleri (27001)
Üst yönetim taahhüdü ve gözden geçirme	İş etki analizi ve süreklilik planları (22301)
Belge ve kayıt kontrolü	Hizmet yönetimi süreçleri (20000-1)
İç denetim programı	Gizlilik kontrolleri (27701)
Uygunsuzluk ve düzeltici faaliyet süreci	Müşteri odaklılık ve ürün kalitesi (9001)
İletişim ve yetkinlik yönetimi	

Pratik kazanım
Tek bir iç denetim programında birden fazla standardı birlikte denetleyebilir, tek bir yönetimin gözden geçirmesi toplantısında tüm sistemlerin girdilerini ele alabilirsiniz. Böylece belge, toplantı ve denetim yükünüz azalır; tutarlılık artar.

2022 sürümü: Ek A kontrolleri

Önceki sürüme göre sadeleşen ve dört temada toplanan kontrol seti.



Şekil 18 · Ek A'daki 93 kontrolün temalara dağılımı

2022 sürümünde on bir yeni kontrol eklendi:

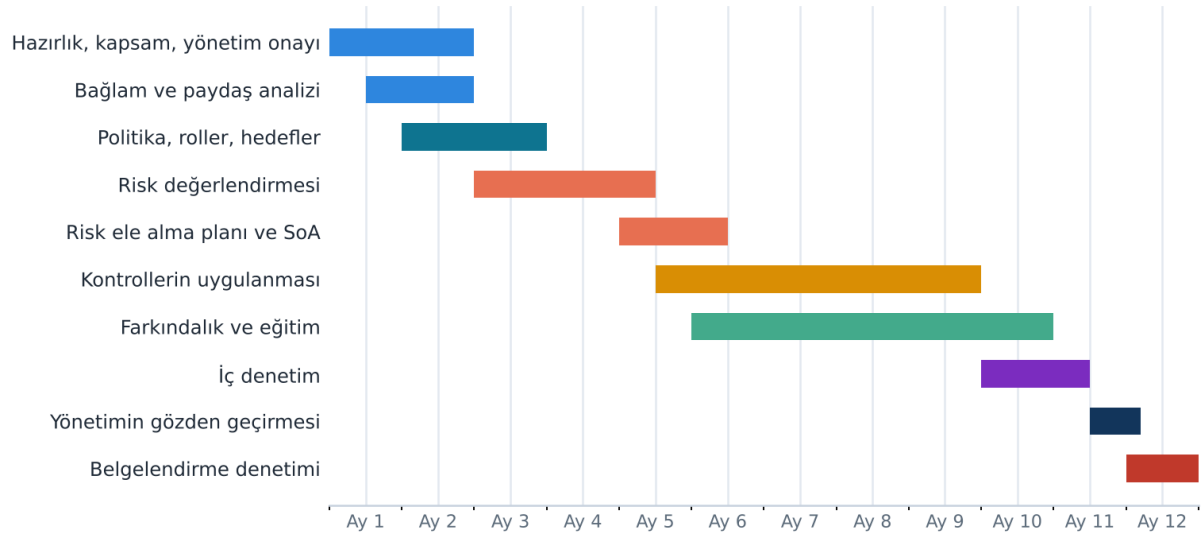
No	Kontrol	Tema
5.7	Tehdit istihbaratı	Organizasyonel
5.23	Bulut hizmetlerinde bilgi güvenliği	Organizasyonel
5.30	İş sürekliliği için BİT hazırlığı	Organizasyonel
7.4	Fiziksel güvenlik izleme	Fiziksel
8.9	Yapılandırma yönetimi	Teknolojik
8.10	Bilgi silme	Teknolojik
8.11	Veri maskeleme	Teknolojik
8.12	Veri sızıntısı önleme	Teknolojik
8.16	İzleme faaliyetleri	Teknolojik
8.23	Web filtreleme	Teknolojik
8.28	Güvenli kodlama	Teknolojik

Önemli hatırlatma
Ek A, yapılacakların tam listesi değildir; **risk ele alma sürecinde seçtiğiniz kontrolleri doğrulamak** için bir referanstır. Kontrolleri çıkarırsanız veya eklerseniz bunun gerekçesi SoA'da yer almalıdır. Ek A'da bulunmayan, kuruma özgü kontroller de eklenebilir.

12 aylık yol haritası

Belgelendirmeye hazırlanan orta ölçekli bir kurum için tipik bir akış.

Tipik 12 aylık kuruluş takvimi (kuruma göre değişir)



Şekil 19 · Tipik 12 aylık kuruluş takvimi (kapsam ve olgunluğa göre değişir)

Denetime hazırlık kontrol listesi

☐ Kapsam beyanı yazılı, onaylı ve güncel mi?	☐ Kontroller çalışıyor, kanıtı var mı?
☐ İlgili taraflar ve gereksinimleri listelendi mi?	☐ İzleme sonuçları ve göstergeler toplanıyor mu?
☐ Politika üst yönetimce onaylı ve duyuruldu mu?	☐ Farkındalık eğitimleri verildi, kayıtlı mı?
☐ Hedefler ölçülebilir ve sahipli mi?	☐ Tedarikçi envanteri ve değerlendirmeleri güncel mi?
☐ Roller atandı, yetkinlik kanıtlı mı?	☐ Olay süreci tatbik edildi, kayıtlar var mı?
☐ Risk yöntemi ve kabul kriteri onaylı mı?	☐ İç denetim yapıldı, bulgular kapatıldı mı?
☐ Risk değerlendirmesi güncel, riskler sahipli mi?	☐ Yönetimin gözden geçirmesi yapıldı, kararlar kayıtlı mı?
☐ Risk ele alma planı ve SoA tamam mı?	☐ Uygunsuzluklar kök nedenle yönetiliyor mu?

Rol bazlı hızlı rehber

ISO 27001 BGYS ile muhatap olan herkes için: sizden ne bekleniyor?

Rol	Sizden beklenen üç şey	İlgili bölümler
Üst yönetim	Sorumluluğu üstlenin · Kaynak ve yön verin · Yönetimin gözden geçirmesini yapın	2, 3, 7, 14
BG yöneticisi / proje ekibi	Sistemi kurun ve işletin · Riski yönetin · Yönetime raporlayın	Tümü
Risk ve süreç sahipleri	Riskinizin sahibi olun · Kontrolleri işletin · Kabul kararlarını onaylayın	5, 6, 7
BT ve teknik ekipler	Kontrolleri uygulayın ve kanıtlayın · Olayları bildirin · Değişikliklerde risk analizi	6, 7, 13
İK, hukuk, satın alma	İşe giriş-çıkış güvenliği · Sözleşme ve mevzuat · Tedarikçi yönetimi	9, 10, 11
Tüm çalışanlar	Politikayı bilin · Şüpheli durumu bildirin · Eğitimlere katılın	4, 10, 13
İç denetçiler	Bağımsız ve kanıta dayalı denetleyin · Bulguları kapatın · Yönetime raporlayın	12, 14
Tedarikçiler	Sözleşmedeki güvenlik şartlarını karşılayın · Olayları süresinde bildirin · Denetime açık olun	11, 13

Sözlük

Sık karşılaşılan kavramlar.

Terim	Anlamı
BGYS	Bilgi Güvenliği Yönetim Sistemi: bilgi güvenliğini planlı, ölçülebilir ve sürekli iyileştirilen biçimde yöneten sistem.
Gizlilik / Bütünlük / Erişilebilirlik	Bilgi güvenliğinin üç temel hedefi.
İlgili taraf	BGYS'yi etkileyen veya ondan etkilenen kişi ve kuruluşlar (müşteri, düzenleyici, çalışan, tedarikçi…).
Risk sahibi	Riskin iş etkisini taşıyan ve ele alma kararını verebilecek yönetici.
Artık risk	Risk ele alma sonrasında geriye kalan risk; risk sahibince kabul edilmelidir.
SoA (Uygulanabilirlik Bildirgesi)	Hangi kontrollerin neden uygulandığı veya uygulanmadığının gerekçeli listesi.
KPI / KRI / KCI	Performans, risk ve kontrol etkinliği göstergeleri.
BIA	İş etki analizi: kesintinin iş süreçlerine etkisinin ve kabul edilebilir kesinti süresinin belirlenmesi.
Uygunsuzluk	Bir gereksinimin karşılanmaması.
Düzeltici faaliyet	Uygunsuzluğun nedenini ortadan kaldırarak tekrarını önleyen faaliyet.

Kaynakça ve dayanak standartlar

- ISO/IEC 27001:2022 (Amd 1:2024) · Bilgi güvenliği yönetim sistemleri · Şartlar | ISO/IEC 27002:2022 · Kontroller
- ISO/IEC 27005:2022 · Bilgi güvenliği risk yönetimi | ISO 31000:2018 · Risk yönetimi
- ISO/IEC 27007:2020 ve ISO 19011:2018 · Denetim rehberleri | ISO/IEC 27014:2020 · Yönetişim
- 6698 sayılı Kişisel Verilerin Korunması Kanunu ve ilgili Kurul kararları

Önemli not: Bu belge, standardın şartlarına yönelik özgün bir eğitim özetidir ve standart metninin yerini almaz. Belgelendirme veya hukuki yükümlülükler söz konusu olduğunda standardın güncel resmi metnine ve ilgili mevzuata başvurun. Örnek veriler ve rakamlar (panolar, simülasyon sonuçları, süreler) açıklayıcı amaçlı kurgusaldır.